



Q7

Prepare and present the breach analysis report

10 Marks

Objective: Combine the outputs of Q1–Q6 into a short, structured breach analysis report with findings, risk interpretation and lessons learned.

Step-by-Step Algorithm

Step	Phase	Action	Command / Tool	What You Should See
1	SETUP	Collect your completed tables from Q1–Q6.	Q1–Q6 outputs	All tables gathered
2	REPORT	Write an executive summary (3–4 sentences) of the breach.	Summary	Executive summary
3	REPORT	Add sections: background, CIA, kill chain, risk matrix, mitigations, CSF gaps.	Report structure	Draft report
4	ANALYSE	Write a lessons-learned section with 3–5 concrete takeaways.	—	Lessons learned
5	TEST	Proofread for clarity and check every claim traces to evidence.	Review checklist	Report reviewed
6	REPORT	Export the report and prepare a short presentation.	PDF / slides	Final deliverables

Phase key: ● SETUP · ● CONFIGURE · ● EXECUTE · ● TEST · ● ANALYSE · ● REPORT · ● FINISH

Worked Example (with sample values & output)

Report structure (Acme HealthCare)

Section	Content	Comes from
1. Executive Summary	3-4 sentence overview of the breach	New
2. Incident Background	Verified facts and timeline	Q2
3. Threat Classification	CIA impact of each action	Q1
4. Attack Mapping	Kill chain + ATT&CK techniques	Q3
5. Risk Assessment	Prioritised risk matrix	Q4
6. Recommended Mitigations	Preventive / detective / corrective	Q5
7. NIST CSF Gap Analysis	Function ratings and gaps	Q6
8. Lessons Learned	3-5 concrete, actionable takeaways	New

Sample lessons learned: deploy MFA on all accounts; add attachment sandboxing to email; monitor for large data exports; and test backups quarterly.

Reusable Template

Submission checklist



✓	Check before submitting
☒	Executive summary present
☒	All six analysis tables (Q1-Q6) included
☒	Every claim backed by a source or table
☒	Lessons learned are specific and actionable
☒	Report + GitHub link uploaded to ZOSIMA

Your Output / Screenshot (paste result here):

Capital One breach (2019):

1. Executive Summary:

In July 2019, Capital One disclosed that a former Amazon Web Services (AWS) employee, Paige Thompson, had exploited a misconfigured web application firewall (WAF) to breach its cloud infrastructure and steal data belonging to approximately 106 million customers and credit-card applicants across the US and Canada. The attacker used a Server-Side Request Forgery (SSRF) technique to trick the WAF into requesting AWS's internal metadata service, which handed over temporary security credentials for an over-privileged IAM role. Those credentials were then used to access and exfiltrate data from over 700 Amazon S3 storage buckets. The breach went undetected for roughly four months until an outside party tipped off Capital One after the attacker boasted about it online, resulting in an \$80 million regulatory fine and a \$190 million customer settlement.

2. Incident Background

Who: Capital One (major US bank and credit-card issuer), hosted on AWS

What: Theft of applicant and customer data — names, addresses, phone numbers, dates of birth, self-reported income, credit scores, credit limits, account balances, payment history, and fragments of transaction data; also ~140,000 Social Security numbers and ~80,000 linked bank account numbers

When: Intrusion occurred in March 2019; discovered and disclosed in July 2019

How discovered: An external researcher notified Capital One after finding the attacker's own post (on GitHub/Slack) describing the stolen data

Data affected: ~106 million individuals (~100M in the US, ~6M in Canada)

(Sources: Capital One 8-K SEC filing, July 2019; US DOJ press release, 29 Jul 2019; OCC consent order, Aug 2020.)

3. Threat Classification (CIA Triad)

Attacker action	CIA element broken	Security goal failed
Exploited SSRF flaw in the misconfigured WAF	Confidentiality	Access control on the web app perimeter
Retrieved AWS IAM role credentials via the metadata service	Confidentiality	Credential secrecy
Used stolen credentials to access 700+ S3 buckets and exfiltrate data	Confidentiality	Data secrecy

Verdict: Confidentiality was the only CIA element materially violated — no data was altered (Integrity intact) and no service was disrupted (Availability intact). This is a "pure exfiltration" breach, unlike Yahoo's, which also broke Integrity via forged authentication.

4. Attack Mapping — Kill Chain + ATT&CK Techniques

Kill Chain Stage	What Happened	MITRE ATT&CK Technique
Reconnaissance	Attacker (a former AWS engineer) identified misconfigured firewalls on companies' cloud infrastructure, including Capital One's	T1595 – Active Scanning
Weaponization	Crafted an SSRF request designed to reach AWS's internal instance metadata endpoint	T1190 – Exploit Public-Facing Application
Delivery	Sent the malicious request directly to Capital One's public-facing web application	T1190 – Exploit Public-Facing Application
Exploitation	The misconfigured WAF forwarded the SSRF request, allowing it to reach the metadata service	T1552.005 – Unsecured Credentials: Cloud Instance Metadata API
Installation	No malware installed — attacker operated using legitimate stolen IAM credentials	T1078.004 – Valid Accounts: Cloud Accounts
Command & Control	Used the stolen temporary credentials directly via AWS CLI/API — no separate C2 channel needed	T1552.005 (same credential misuse continued)



Actions on Objectives	Listed and downloaded data from 700+ S3 buckets	T1530 – Data from Cloud Storage Object; T1567 – Exfiltration Over Web Service
-----------------------	---	---

5. Risk Assessment – Prioritised Risk Matrix:

Risk	Likelihood	Impact	Priority
Over-privileged IAM role exploitable via SSRF	Certain (occurred)	Critical	Critical
Mass PII/financial data exposure (106M individuals)	Certain (occurred)	Critical	Critical
Exposure of SSNs and bank account numbers	High	Critical	Critical
Lack of egress/anomaly monitoring on large S3 pulls	High	High	High
Insider knowledge of cloud infrastructure (ex-AWS employee)	Medium	High	Medium–High
Regulatory and legal exposure	High	High	High

6. Recommended Mitigations:

Preventive:

- Enforce least-privilege IAM roles – the WAF's role should never have had permission to list/read all S3 buckets
- Disable or restrict access to the AWS Instance Metadata Service (use IMDSv2, which requires a session token and blocks basic SSRF from reaching it)
- Patch/reconfigure WAF rules to detect and block SSRF-style requests targeting internal IP ranges (e.g., 169.254.169.254)
- Apply network segmentation between public-facing applications and internal cloud credential services

Detective:

- Monitor for anomalous IAM role usage (e.g., a WAF role suddenly listing hundreds of S3 buckets)
- Alert on large or unusual data egress volumes from storage buckets
- Enable AWS CloudTrail logging with active review, not just passive storage
- Monitor public code/paste sites (GitHub, Pastebin) for leaked credentials or boasts referencing your organization



Corrective:

- Immediately revoke and rotate any credentials exposed via a metadata-service compromise
- Maintain an incident response plan with defined roles for cloud-specific breaches
- Notify affected individuals and regulators promptly (Capital One's ~4-month detection gap significantly increased both damage and fine exposure)
- Offer credit monitoring to affected individuals given SSN/bank account exposure

7. NIST CSF Gap Analysis:

Function	Rating	Gap Identified
Identify	Initial	The WAF's IAM permissions weren't assessed as high-risk despite broad S3 access
Protect	Initial	No IMDSv2 enforcement; overly broad IAM policy; no SSRF-specific WAF rules
Detect	Initial	No alerting on abnormal S3 access patterns — breach was found externally, not internally
Respond	Developing	Once notified, Capital One acted quickly to close the hole and notify regulators
Recover	Developing	Recovery involved regulatory fines, customer settlement, and infrastructure hardening rather than a pre-built cloud recovery plan

8. Lessons Learned:

1. Apply least-privilege IAM policies rigorously — a WAF service account should never be able to read data it has no functional need to access.
2. Enforce IMDSv2 (or equivalent) on all cloud compute resources to close off the single technique this entire breach depended on.
3. Build detection specifically for cloud data-access anomalies (bulk S3 reads, unusual API call patterns) — prevention alone failed here, as it does in most large breaches.
4. Treat WAF and firewall configurations as security-critical assets requiring regular audit, not "set and forget" infrastructure.
5. Reduce detection-to-disclosure time — a shorter gap between compromise and discovery directly reduces both damage and regulatory penalty exposure.



K.R. MANGALAM UNIVERSITY
THE COMPLETE WORLD OF EDUCATION
